

# **DAMM v2**

## **Release 0.2.1**

### **Smart Contract Security Assessment**

**May 2026**

**Prepared for:**

**Meteora**

**Prepared by:**

**Offside Labs**

*Sirius Xie*





# Contents

|          |                                                               |          |
|----------|---------------------------------------------------------------|----------|
| <b>1</b> | <b>About Offside Labs</b>                                     | <b>2</b> |
| <b>2</b> | <b>Executive Summary</b>                                      | <b>3</b> |
| <b>3</b> | <b>Summary of Findings</b>                                    | <b>5</b> |
| <b>4</b> | <b>Key Findings and Recommendations</b>                       | <b>6</b> |
| 4.1      | Incorrect System Program validation in Anchor 1.0.0 . . . . . | 6        |
| <b>5</b> | <b>Disclaimer</b>                                             | <b>8</b> |



# 1 About Offside Labs

**Offside Labs** is a leading security research team, composed of top talented hackers from both academia and industry.

We possess a wide range of expertise in modern software systems, including, but not limited to, *browsers*, *operating systems*, *IoT devices*, and *hypervisors*. We are also at the forefront of innovative areas like *cryptocurrencies* and *blockchain technologies*. Among our notable accomplishments are remote jailbreaks of devices such as the **iPhone** and **PlayStation 4**, and addressing critical vulnerabilities in the **Tron Network**.

Our team actively engages with and contributes to the security community. Having won and also co-organized *DEFCON CTF*, the most famous CTF competition in the Web2 era, we also triumphed in the **Paradigm CTF 2023** within the Web3 space. In addition, our efforts in responsibly disclosing numerous vulnerabilities to leading tech companies, such as *Apple*, *Google*, and *Microsoft*, have protected digital assets valued at over **\$300 million**.

In the transition towards Web3, Offside Labs has achieved remarkable success. We have earned over **\$9 million** in bug bounties, and **three** of our innovative techniques were recognized among the **top 10 blockchain hacking techniques of 2022** by the Web3 security community.



<https://offside.io/>



<https://github.com/offsidelabs>



[https://twitter.com/offside\\_labs](https://twitter.com/offside_labs)



## 2 Executive Summary

### Introduction

Offside Labs completed a security audit of *DAMM v2* smart contracts, starting on May 8th, 2026, and concluding on May 20th, 2026.

### Project Overview

Meteora DAMM v2 Release 0.2.1 adds a new protocol fee claiming flow that routes fee collection through the protocol-fee program and introduces a dedicated protocol fee authority. The release also updates pool fee management so operators can adjust the compounding fee setting for pools that use compounding fee collection. The previous protocol fee claiming and zapping flows are deprecated, while the core pool account layout remains unchanged.

### Audit Scope

The assessment scope contains mainly the smart contracts of the cp-amm program for the *DAMM v2* project.

The audit is based on the following specific branches and commit hashes of the codebase repositories:

- DAMM v2
  - Codebase: <https://github.com/MeteoraAg/damm-v2>
  - Release 0.2.1: [PR-200](#)
  - Commit Hash: b22a28f4fd9130aa3c46be3bd9633356e621f9eb

The issues described in this report have been resolved by the following commit:

- DAMM v2
  - Codebase: <https://github.com/MeteoraAg/damm-v2>
  - Commit Hash: 9d19bc18bbf0d287bbe814bca08791cec420ab67

We listed the files we have audited below:

- DAMM v2
  - programs/cp-amm/src/const\_pda.rs
  - programs/cp-amm/src/constants.rs
  - programs/cp-amm/src/entrypoint.rs
  - programs/cp-amm/src/error.rs
  - programs/cp-amm/src/event.rs
  - programs/cp-amm/src/instructions/admin/auth.rs
  - programs/cp-amm/src/instructions/initialize\_pool/ix\_initialize\_customizable\_pool.rs
  - programs/cp-amm/src/instructions/initialize\_pool/ix\_initialize\_pool.rs
  - programs/cp-amm/src/instructions/initialize\_pool/ix\_initialize\_pool\_with\_dynamic\_config.rs



- programs/cp-amm/src/instructions/ix\_close\_position.rs
- programs/cp-amm/src/instructions/ix\_create\_position.rs
- programs/cp-amm/src/instructions/ix\_refresh\_vesting.rs
- programs/cp-amm/src/instructions/ix\_split\_position2.rs
- programs/cp-amm/src/instructions/operator/ix\_claim\_protocol\_fee.rs
- programs/cp-amm/src/instructions/operator/ix\_claim\_protocol\_fee2.rs
- programs/cp-amm/src/instructions/operator/ix\_fix\_config\_fee\_params.rs
- programs/cp-amm/src/instructions/operator/ix\_fix\_pool\_fee\_params.rs
- programs/cp-amm/src/instructions/operator/ix\_initialize\_reward.rs
- programs/cp-amm/src/instructions/operator/ix\_update\_pool\_fees.rs
- programs/cp-amm/src/instructions/operator/ix\_update\_reward\_duration.rs
- programs/cp-amm/src/instructions/operator/ix\_update\_reward\_funder.rs
- programs/cp-amm/src/instructions/operator/ix\_zap\_protocol\_fee.rs
- programs/cp-amm/src/instructions/operator/mod.rs
- programs/cp-amm/src/instructions/swap/ix\_p\_swap.rs
- programs/cp-amm/src/lib.rs
- programs/cp-amm/src/math/safe\_math.rs
- programs/cp-amm/src/state/pool.rs
- programs/cp-amm/src/utis/alpha\_vault.rs
- programs/cp-amm/src/utis/p\_helper.rs
- programs/cp-amm/src/utis/token.rs

## Findings

The security audit revealed:

- 0 critical issue
- 1 high issues
- 0 medium issue
- 0 low issue
- 0 informational issue

Further details, including the nature of these issues and recommendations for their remediation, are detailed in the subsequent sections of this report.



### 3 Summary of Findings

| ID | Title                                               | Severity | Status |
|----|-----------------------------------------------------|----------|--------|
| 01 | Incorrect System Program validation in Anchor 1.0.0 | High     | Fixed  |



## 4 Key Findings and Recommendations

### 4.1 Incorrect System Program validation in Anchor 1.0.0

Severity: High

Status: Fixed

Target: Smart Contract

Category: Framework

#### Description

The program is upgraded to Anchor 1.0.0. This Anchor version has a known validation issue for typed program accounts such as `Program<'info, System>`.

In Anchor `1.0.0~1.0.1`, `Program<T>` uses the program id returned by `T::id()` to decide whether the account should be treated as a typed program or as a generic executable program. Since the System Program id is the default public key, `Program<'info, System>` may be misclassified as a generic program account. As a result, Anchor may only check that the provided account is `executable`, without enforcing that its address is the real System Program address.

```
152 // Special handling for unit type () - only check executable, not
    // program ID
153 let is_unit_type = T::id() == Pubkey::default();
154
155 if !is_unit_type && info.key != &T::id() {
156     return
        Err(Error::from(ErrorCode::InvalidProgramId).with_pubkeys(
            (*info.key, T::id())));
157 }
158 if !info.executable {
159     return Err(ErrorCode::InvalidProgramExecutable.into());
160 }
```

[lang/src/accounts/program.rs#L152-L160](#)

The affected code pattern is:

```
pub system_program: Program<'info, System>,
```

The program contains multiple instructions using this pattern for account initialization, account resizing, rent funding, and other system program operations.

#### Impact

An attacker may be able to pass a non System executable program where the real System Program is expected. This can affect instructions that depend on System Program validation for account creation, reallocations, rent transfers, or PDA based setup flows. The



practical impact depends on each call path, but the affected validation is security critical and applies broadly across the program.

### **Recommendation**

It's recommended to upgrade Anchor to version 1.0.2, where this issue is fixed in this commit [commit/3eb1fb0427d4fed0e944b627aef76db651a93aab](https://github.com/project-serapion/anchor-lang/commit/3eb1fb0427d4fed0e944b627aef76db651a93aab).

If the program continues to use Anchor 1.0.0 or 1.0.1, explicitly constrain every System Program account to the canonical System Program address, for example:

```
#[account(address = anchor_lang::system_program::ID)]  
pub system_program: Program<'info, System>,
```

### **Mitigation Review Log**

Fixed in the commit 980724ad0b524b0dac1c799fb25070c14eea5ab7.





## 5 Disclaimer

This audit report is provided for informational purposes only and is not intended to be used as investment advice. While we strive to thoroughly review and analyze the smart contracts in question, we must clarify that our services do not encompass an exhaustive security examination. Our audit aims to identify potential security vulnerabilities to the best of our ability, but it does not serve as a guarantee that the smart contracts are completely free from security risks.

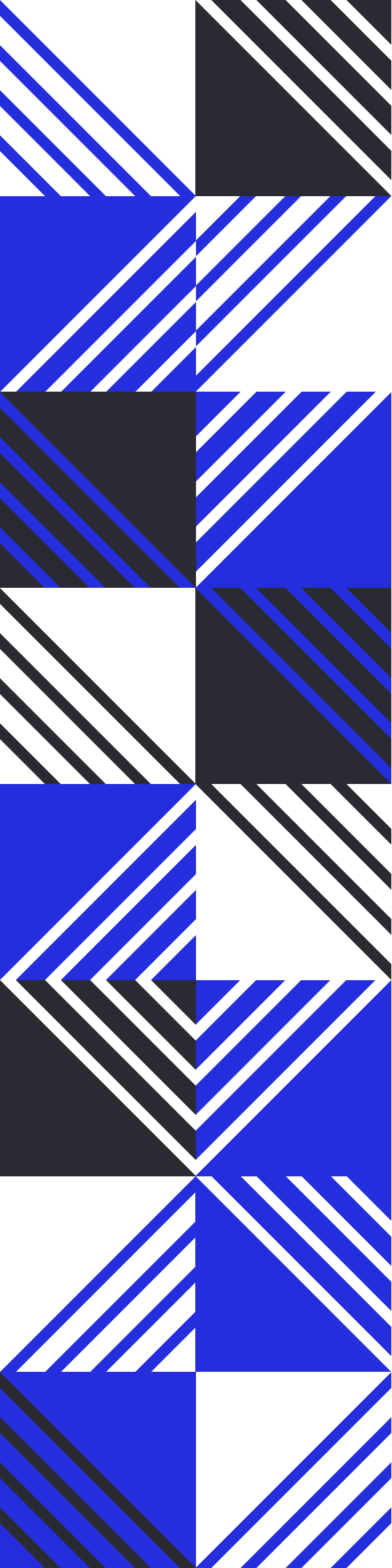
We expressly disclaim any liability for any losses or damages arising from the use of this report or from any security breaches that may occur in the future. We also recommend that our clients engage in multiple independent audits and establish a public bug bounty program as additional measures to bolster the security of their smart contracts.

It is important to note that the scope of our audit is limited to the areas outlined within our engagement and does not include every possible risk or vulnerability. Continuous security practices, including regular audits and monitoring, are essential for maintaining the security of smart contracts over time.

Please note: we are not liable for any security issues stemming from developer errors or misconfigurations at the time of contract deployment; we do not assume responsibility for any centralized governance risks within the project; we are not accountable for any impact on the project's security or availability due to significant damage to the underlying blockchain infrastructure.

By using this report, the client acknowledges the inherent limitations of the audit process and agrees that our firm shall not be held liable for any incidents that may occur subsequent to our engagement.

This report is considered null and void if the report (or any portion thereof) is altered in any manner.



 <https://offside.io/>

 <https://github.com/offsidelabs>

 [https://twitter.com/offside\\_labs](https://twitter.com/offside_labs)